

Engagement Management

Chapter 1

1.01

Episode title: **Planning a Pen Test**

Objective: **1.1 Compare and contrast governance, risk, and compliance concepts**
1.2 Explain the importance of scoping and organizational/customer requirements

TARGET AUDIENCE

- **Recommended experience**
 - 3 to 4 yrs in penetration testing or equivalent
- **Cybersecurity professionals with intermediate skill level**
 - Active in hands-on penetration testing

PENTEST+ EXAM OBJECTIVES

DOMAIN	PERCENTAGE OF EXAM
1.0 Engagement Management	13%
2.0 Reconnaissance and Enumeration	21%
3.0 Vulnerability Discovery and Analysis	17%
4.0 Attacks and Exploits	35%
5.0 Post-exploitation and Lateral Movement	14%
TOTAL	100%

1.0 Engagement Management

- **Get permission**
- **Know how much work you have to do**
 - Don't do more than that
- **Watch out for scope creep**

PLANNING A PEN TEST

- **Penetration Testing
Execution Standard**

- http://www.pentest-standard.org/index.php/Main_Page
- Defines seven sections of a penetration test

PLANNING A PEN TEST

- **Pen test sections**

- Pre-engagement interactions
- Intelligence Gathering
- Threat Modeling
- Vulnerability Analysis
- Exploitation
- Post Exploitation
- Reporting

THE IMPORTANCE OF PLANNING

- **Each section of a pen test is important**
- **Each step is important**
- **Don't skip steps**
 - You might miss an exploit
 - You might scope the test improperly

THE IMPORTANCE OF PLANNING

- **Lots of options in each step**
- **Each pen test often conducted differently**
- **Easy to waste time and effort**
 - Experience helps avoid this
- **Project management skills are important here**

1.02

Episode title: **Rules of Engagement**

Objective: **1.1 Compare and contrast governance, risk, and compliance concepts**

TARGET AUDIENCE AND ROE

- **Know your target audience**

- Who is sponsoring the pen test?
- What is the purpose for the test?

- **Rules of engagement – governs the pen tester's activities**

- Schedule - start, stop, temporal restrictions
- Team composition, location, access

TARGET AUDIENCE AND ROE

- **Test scope**

- Technical/physical/ personnel
- Target limits (inclusion, invasiveness, etc.)

COMMUNICATION ESCALATION PATH

- **Risks of pen testing**

- Crashing devices, services, whole servers
- Corrupting data
- Degrading performance
- Terms of Service (TOS) /regulation/legislation violation

- **Communication escalation path**

- Who to contact if things go wrong
- Communication expectations (content, trigger, frequency)

1.03

Episode **Collaboration and Communication**
title:

Objective: **1.2.1, 1.2.3, 1.2.5, 1.2.8, 1.2.9**

Best Practices

- Use peer review for quality
- Perform root cause analysis
- Ensure secure and approved processes

1.04

Episode title: **Regulatory Compliance**

Objective: **1.1 Compare and contrast governance, risk, and compliance concepts**

L3s

- https://www.pcisecuritystandards.org/documents/Penetration-Testing-Guidance-v1_1.pdf

REGULATORY COMPLIANCE CONSIDERATIONS

- **Payment Card Industry Data Security Standard (PCI DSS)**
 - Industry standard of security requirements for payment card processing
 - PCI DSS requirement 11
 - Internal and external testing
 - Annually
 - After significant infrastructure changes

REGULATORY COMPLIANCE CONSIDERATIONS

- **General Data Protection Regulation (GDPR)**
 - European Union (EU) regulation
 - Data protection and privacy for all individuals in the EU
 - Give control to individuals over their personal data
 - Article 32(1) requires “a process for regularly testing, assessing and evaluating the effectiveness of technical and organisational measures for ensuring the security of the processing”

1.05

Episode title: **Impact and Constraints**

Objective: **1.3 Given a scenario, demonstrate an ethical hacking mindset by maintaining professionalism and integrity**

SET EXPECTATIONS

- **Impact**

- The result of testing
- Report vulnerabilities
- Remediation
 - How should client respond?

SET EXPECTATIONS

- **Disclaimers**

- Point-in-time assessment
 - Only valid now
- Comprehensiveness
 - Enterprise/division/
department, etc.

TECHNICAL CONSTRAINTS

- **Any technical limitations that reduce test scope**
- **Production (live) components**
- **Out-of-service devices**
- **Can't access**
 - Physical/geographic access limitations
 - Legal/regulatory/out of scope

1.06

Episode title: **Legal Groundwork**

Objective: **1.3 Compare and contrast governance, risk, and compliance concepts**

LEGAL CONCEPTS

- **Statement of work (SOW)**

- Clearly states what tasks are to be accomplished

- **Master Service Agreement (MSA)**

- Specifies details of the business arrangement

- **Non-Disclosure Agreement (NDA)**

- Agreement that defines confidentiality, restrictions and/or sharing information

ENVIRONMENTAL DIFFERENCES

- **Export restrictions – restrictions on shipment or transfer of technology or services outside the U.S.**
 - See U.S. State Department resource - <https://www.state.gov/strategictrade/overview/>
- **Local and national government restrictions – laws and regulations differ among countries**
 - A legal action in one country may be illegal in another
- **Corporate policies – differ between most organizations**

ENVIRONMENTAL DIFFERENCES

- **Export restrictions – restrictions on shipments, transfer of technology, or services outside the U.S.**
 - See U.S. State Department resource - <https://www.state.gov/strategictrade/overview/>

ENVIRONMENTAL DIFFERENCES

- **National or local restrictions**
 - Differ among countries
 - Local customs differ
- **Corporate policies**
 - Differ between most organizations

WRITTEN AUTHORIZATION

- **Obtain signature from proper signing authority**
 - Pen tests can reveal sensitive or confidential information
 - Activities may be illegal without proper permission
 - Signed permission makes you a white hat
- **Third-party provider authorization if necessary**
 - Get permission for any outside resources you use in tests
 - Internet, Cloud, and distributed resource that isn't owned by the entity sponsoring the pen test

WRITTEN AUTHORIZATION

- **Obtain signature from proper signing authority**

- “Get out of jail free” card
- Pen tests can reveal sensitive or confidential information
- Activities may be illegal without proper permission
- Signed permission makes you a white hat pen tester

WRITTEN AUTHORIZATION

- **Third-party authorization when necessary**

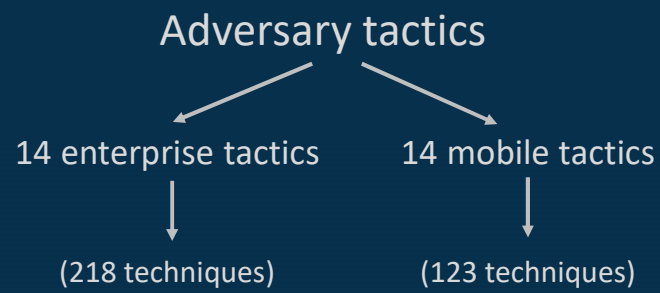
- Ex: from a Cloud service provider
- Get permission for any outside resources used
 - Cloud, Internet (ISP usage), etc

1.07

Episode title: **Standards and Methodologies,
Part 1**

Objective: **1.2 Explain the importance of scoping and
organizational/customer requirements**

MITRE ATT&CK



<https://attack.mitre.org>

STANDARDS AND METHODOLOGIES

- **Open Web Application Security Project (OWASP)**

- Nonprofit resource to help make web applications more secure
- OWASP Top 10
- <https://owasp.org>

1.08

Episode title: **Standards and Methodologies,
Part 2**

Objective: **1.2 Explain the importance of scoping and
organizational/customer requirements**

STANDARDS AND METHODOLOGIES

- **National Institute of Standards and Technology (NIST)**
 - U.S. standards authority
 - <https://www.nist.gov>
 - NIST Cybersecurity Framework (CSF)
 - <https://www.nist.gov/cyberframework>
 - NIST Special Publication (SP) 800-171 - 3.11.2, 3.11.3
 - <https://csrc.nist.gov/publications/detail/sp/800-171/rev-2/final>
 - NIST SP 800-53 Rev 5
 - <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>

STANDARDS AND METHODOLOGIES

- **Open-source Security Testing Methodology Manual (OSSTMM)**
 - Dated, open-source manual for testing security controls
 - <https://untrustednetwork.net/files/osstmm.en.2.1.pdf>
- **Penetration Testing Execution Standards (PTES)**
 - <http://www.pentest-standard.org>

STANDARDS AND METHODOLOGIES

- **Information Systems Security Assessment Framework (ISSAF)**
 - Comprehensive security assessment framework
 - Dated, but open-source and extensive
 - <https://untrustednetwork.net/files/issaf0.2.1.pdf>

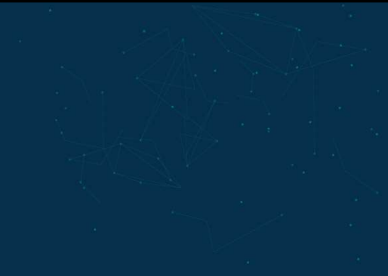
1.09

Episode title: **Standards and Methodologies
Part 3**

Objective: **Frameworks and methodologies: 1.3.2, 1.3.6, 1.3.7 -
Threat modeling frameworks: 1.3.8 (a,b,c)**

L3s

- **Purdue model**



CREST FRAMEWORK

- Pen testing
- Incident response
- Threat intelligence
- Ethical standards and professionalism
- Focused on regulated industries

MASVS FRAMEWORK

- Sets security requirements for mobile apps
- Aids developers in defining assurance levels

DREAD

- **Evaluate and prioritize risk**

- Damage potential
- Reproducibility
- Exploitability
- Affected users
- Discoverability

STRIDE

- **Developed by Microsoft**
- **Identify common threats**
 - Spoofing
 - Tampering
 - Repudiation
 - Information disclosure
 - Denial of service
 - Elevation of privilege
- **Maps to security property**
 - Confidentiality
 - Integrity

OCTAVE

- **Identifies and manages threats based on business priority**
- **Operational Critical Threat Asset Vulnerability Evaluation (OCTAVE)**
 - Asset criticality
 - Business impact
 - Stakeholder input
- **Aimed at enterprise-level threat modeling**

1.10

Episode title: **Environmental and Scoping Considerations**

Objective: **1.2 Explain the importance of scoping and organizational/customer requirements**

ENVIRONMENTAL CONSIDERATIONS

- **Network**

- Physical vs. virtual segmentation
- Wired vs. wireless
- Media
- LAN vs. MAN vs. WAN

ENVIRONMENTAL CONSIDERATIONS

- **Application**

- Nature of application(s) in use
- Third-party or internally developed
- Architecture

ENVIRONMENTAL CONSIDERATIONS

- **Cloud**

- Private vs. public vs. hybrid
- On-premises vs. cloud distribution

IN-SCOPE ASSETS

- Wireless networks
- IP ranges
- Domains, forests, organizational units (OUs) in Active Directory
- Application programming interfaces (APIs)
- Domain Name System (DNS)

SCOPING THE ENGAGEMENT

- **Types of assessment**

- Goals-based/objectives-based
 - Goals-based – Goals set up front, testers work to fulfill goals
 - Objective-based – Assets to protect are defined and testers use all angles to attack protected objectives
- Compliance-based
 - Used to show compliance (i.e. PCI-DSS)
- Red team
 - Ongoing team that acts like attackers to use any means to access objective(s)
 - A single compromise is success

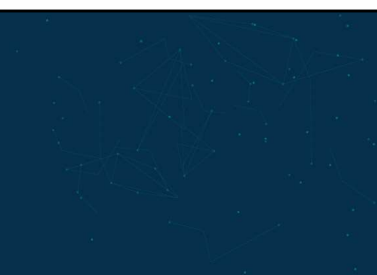
1.11

Episode **Lab Environment Setup**
title:

Objective:

Demo

- Introduction to class environment



1.12

Episode **Project Strategy and Risk**
title:

Objective: **1.2 Explain the importance of scoping and
organizational/customer requirements**

CONSIDERATIONS

- **White-listed**

- No one can access resources unless specifically granted

- **Black-listed**

- Everyone can access unless specifically blocked

CONSIDERATIONS

- **Security exceptions**

- Intrusion Prevention System (IPS)
Web application firewall (WAF) whitelist
- Network Access Control (NAC)
- Certificate pinning (public key pinning)

- **Explore company policies to learn about security considerations**

STRATEGY

- **Black box**
 - Zero prior information
 - Most similar to real attacker
 - Test is generally a surprise to all internal personnel
- **White box**
 - Full access to internal information
 - Simulates insider attack
- **Gray box**
 - Some internal information available
 - Consistent with an insider attack with limited access

RISK ACCEPTANCE

- **Pen tests can be risky**
 - Service can be interrupted
 - Devices/servers can become unresponsive
- **How much risk is the client willing to accept?**
 - Client has identified risks
 - Acceptance: willing to accept risks, based on likelihood and impact
- **Tolerance to impact**
 - If risk is realized, what is client's tolerance to the result?
 - How much disruption is tolerable?